

# DLP incident Response Procedure

**Standard Operating Procedure: DLP Incident Response****Standard Operating Procedure for DLP Incident Response**

|                       |                                           |
|-----------------------|-------------------------------------------|
| <b>Version</b>        | 3.0                                       |
| <b>Effective Date</b> | 31/07/2025                                |
| <b>Compiled by</b>    | Shailendra Singh                          |
| <b>Reviewed by</b>    | Ratnesh Singh                             |
| <b>Approved by</b>    | Chief Information Security Officer (CISO) |

**Revision and Version Control:**

| <b>Version</b> | <b>Date</b> | <b>Reason for Revision/Update</b>      | <b>Created/Updated By</b> | <b>Reviewed By</b> | <b>Approved By</b> |
|----------------|-------------|----------------------------------------|---------------------------|--------------------|--------------------|
| 1.0            | 23-05-2022  | First Copy                             | Shailendra Singh          | Nikhil Bhujade     | CISO               |
| 2.0            | 03-07-2024  | Reviewed                               | Ratnesh Singh             | CISO               | CRO                |
| 3.0            | 31/07/2025  | EDC approved escalation matrix updated | Shailendra Singh          | Ratnesh Singh      | CISO               |



## Standard Operating Procedure: DLP Incident Response

---

### Contents

|                                                           |                              |
|-----------------------------------------------------------|------------------------------|
| 1. Purpose .....                                          | 4                            |
| 2. Scope .....                                            | 4                            |
| 3. Definitions .....                                      | 4                            |
| 4. Data Classification.....                               | 4                            |
| 5. DLP Event Management Workflow .....                    | 4                            |
| 6. DLP operations are categorized into three phases ..... | 5                            |
| 7. Policy Diagram .....                                   | 6                            |
| 8. Incident Response and Reporting/ Escalation phase..... | 6                            |
| 9. Tuning phase: .....                                    | 7                            |
| 10. Exception process:.....                               | 8                            |
| 11. RACI Matrix .....                                     | 8                            |
| 12. DLP Incident Violation Escalation Matrix.....         | Error! Bookmark not defined. |
| 13. Review: .....                                         | 8                            |



## ***Standard Operating Procedure: DLP Incident Response***

---

### **1. Purpose**

The purpose of this document is to provide guidelines and plans for responding to various potential and/or actual DLP incidents.

### **2. Scope**

This procedure applies to Information Systems, Organizational data, Networks and any person or device with access to these systems and data at PFL.

### **3. Definitions**

|      |                                    |
|------|------------------------------------|
| PFL  | Poonawalla Fincorp Limited         |
| DLP  | Data Loss Prevention               |
| CISO | Chief Information Security Officer |
| EDC  | Ethics Disciplinary Committee      |
| HOD  | Head of Department                 |
| SPOC | Single Point of Contact            |

### **4. Data Classification**

#### ***Identification of sensitive data for DLP***

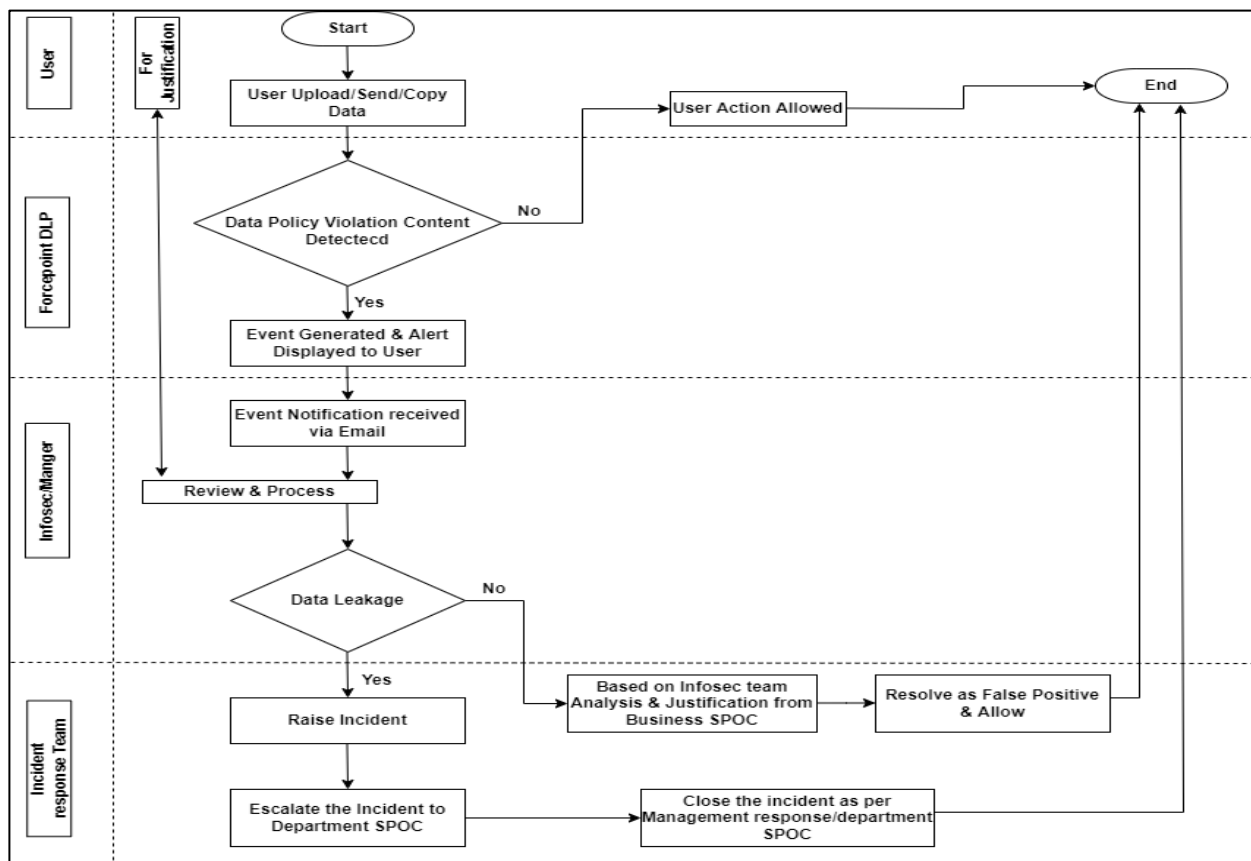
The following data is considered, but not limited to as critical/Sensitive by PFL management.

- Customer Personal Information
- Intellectual Property or organizational critical data
- Financial data
- Sensitive data
- Any other organizational confidential/restricted data

### **5. DLP Event Management Workflow**

Below is an overview of steps for DLP event management at PFL. DLP tool is configured with set of policies on the identified data among data at rest as well as in transit categories.

## Standard Operating Procedure: DLP Incident Response



### 6. DLP operations are categorized into three phases

**Triage Phase (Monitoring):** In this phase will monitor the alert triggered by the policies set up in the DLP tool. Whenever an alert is triggered, PFL Information security team will determine the triage with the following details:

- User Details (who has sent / transferred the data)
- Brief detail of data and its classification (sensitive /critical etc.)
- Channel used for data transfer / Sharing

After performing this triaging, the Information security team will analyze the alert.

#### DLP Incident classifications:

- High - Incidents that match this rule are very important and warrant immediate attention. The policy breach is severe.
- Medium - Incidents that match this rule are of medium importance. The policy breach is moderate.
- Low - Incidents that match this rule are of low importance. The policy breach is minor.

#### Type of policies/Channels configured in DLP

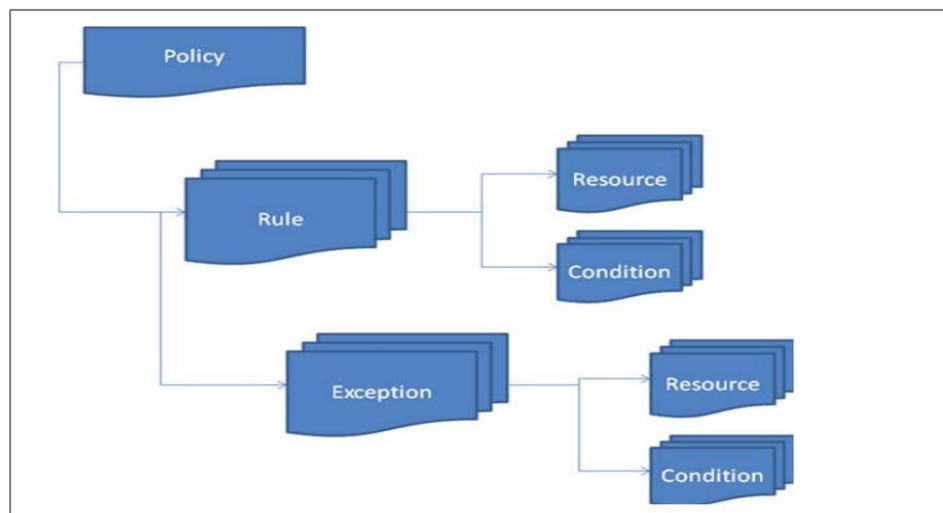
- Email (Network Email) – Analyze email that is sent to the allowed destination email ids and prevent sensitive information from being shared within or outside of PFL domains from both network and endpoint computers.
- Web – Analyze web traffic that is sent to the allowed destination link and protect endpoint devices such as laptops from posting data over the Web.
- Endpoint Printing –Monitor or prevent sensitive data from being printed on local or network printers from endpoint client machines.

## Standard Operating Procedure: DLP Incident Response

- Endpoint Application – Analyze content that is cut, copied, pasted or otherwise handled from the allowed destination application group only.
- Endpoint Removal Media – Monitor or prevent sensitive information from being written to a removable device such as a USB flash drive, CD/DVD, or external hard disk.
- Endpoint LAN – Analyze data content that is copied or transferred to the networks/computers. Users commonly take their laptops home and then copy data through a LAN connection to a network drive/share on another computer.

Note - Classification done by DLP tool can be modified after analysis by Information security team.

### 7. Policy Diagram



### 8. Incident Response and Reporting/ Escalation phase

Information Security team reports the DLP incident/s promptly to respective stakeholders as below:

- Initially, Information security will consult with the respective functional SPOCs to check whether the event is as per business need or not.
- If yes, the event will be considered a false positive and moved to the tuning phase.
- Once an incident is identified as probable true incident<sup>1</sup>, then, ensuring data deletion from external IDs as well as local devices, including mobile phones and laptops. Data deletion evidence must be captured by IT team/ user/ SPOCs and HOD approval from business for closure of the incident. HR to take appropriate action as required on a case-to-case basis.
- The Information Security team will follow the escalation matrix approved by EDC in the event of data leakage violations. **Refer Annexure for details.**
- Based on the criticality and recurrence of DLP incidents, appropriate stakeholders will be involved such as EDC, HR and HOD, Department SPOC.
- **For True incident**, Information Security team will escalate the incident to respective business head and HR (on case-to-case basis) for disciplinary actions and submit the incident report to CISO.
- For all the events/ incidents, the report will be prepared as a part of the monthly deliverable.

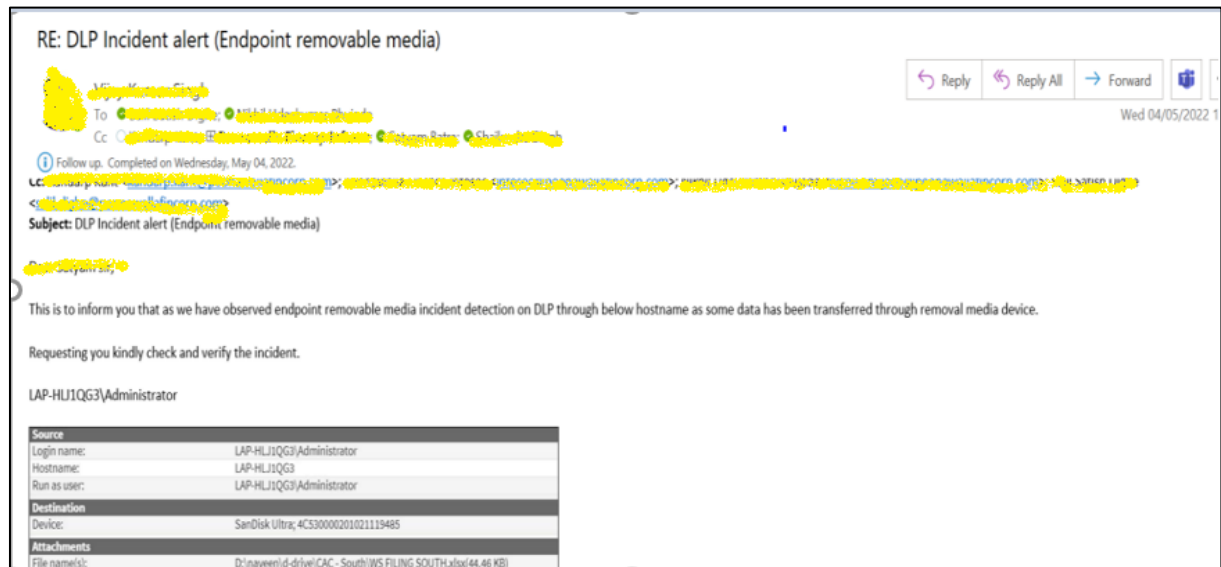


## Standard Operating Procedure: DLP Incident Response

Additionally, reports/ MIS is shared on weekly basis with respective functional SPOCs along with HODs.

1 – Probable True Incidents: Events where data was transferred or shared to external domains, but PFL has taken appropriate action in due time.

### Sample incident alert email:



| Source                                                                                                |                                     |
|-------------------------------------------------------------------------------------------------------|-------------------------------------|
| Full name:                                                                                            | [REDACTED]                          |
| Email address:                                                                                        | [REDACTED]                          |
| Login name:                                                                                           | [REDACTED]                          |
| Manager:                                                                                              | [REDACTED]                          |
| Phone number:                                                                                         | [REDACTED]                          |
| Title:                                                                                                | [REDACTED]                          |
| Department:                                                                                           | [REDACTED]                          |
| Business unit:                                                                                        | Excluded Resources *                |
| * This was not one of the event's original properties.It was determined through user name resolution. |                                     |
| Destination                                                                                           |                                     |
| Email direction:                                                                                      | Outbound                            |
| Email address:                                                                                        | [REDACTED]                          |
| Action taken:                                                                                         | Permitted                           |
| Attachments                                                                                           |                                     |
| File name(s):                                                                                         | Balance Sheet 2021-22.pdf(10.76 MB) |

## 9. Tuning phase:

All the incidents which are considered to be false positive are addressed here during this phase.

- Require fine tune the policies because of some misconfigurations earlier or due to some business change and apply the changes to the DLP as a draft version.
- To check whether the applied changes are fine, the incident is replicated and then checked whether the alert is generated or not.
- If not, then the changes are made final and applied, but if yes then fine tuning is required in the policies which are set up in the DLP.



## **Standard Operating Procedure: DLP Incident Response**

Based on the justifications and approvals from HODs, the policies and use cases will be fine-tuned accordingly.

### **10. Exception process:**

- If any user faces difficulty sharing business related data with vendors/partners for official purpose, then request shall be raised with Information security team to [DLPSupport@poonawallafincorp.com](mailto:DLPSupport@poonawallafincorp.com) & [infosec@poonawallafincorp.com](mailto:infosec@poonawallafincorp.com) for whitelisting.
- Post approval from HOD/ SPOCs and verification of agreement with vendor, exception is created for the user and for specific vendor/partner and email id with confirmation.

### **11. RACI Matrix**

| Activity                        | Responsible               | Accountable                     | Consulted     | Informed                  |
|---------------------------------|---------------------------|---------------------------------|---------------|---------------------------|
| Event Analysis & Classification | Information security team | Information security team       | CISO          | Function SPOCs            |
| Event Confirmation              | Functional SPOCs          | Functional SPOCs                | HOD           | Information Security Team |
| Incident response & reporting   | Information security team | Information security team       | CISO          | Function SPOCs, HOD, HR   |
| Investigation                   | Information security team | Information security team, HODs | CISO          | HOD, HR (if required)     |
| Disciplinary action             | HODs, HR                  | HOD                             | EDC, HODs, HR | Information Security Team |

### **12. Review:**

SOP shall be reviewed at least once annually or as and when changes occur in process.





## Standard Operating Procedure: DLP Incident Response

### Annexure

#### A. Escalation matrix

| Sr. No. | Category | Parameter            | Description                                                                                                                                            | Impact   | First Occurrence                                                                 | Repeated Occurrence                | Remarks                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|---------|----------|----------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------|----------|----------------------------------------------------------------------------------|------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1       | DLP      | Email                | Sharing single Personal identifiable Information (PII) or data of Customer / Company data outside PFL domain through email without required approval.  | High     | Approval from HOD, and cautionary Mail to Employee by manager or Functional Head | To be referred to EDC (through HR) | 1. Ensure the deletion of data from external IDs as well as local devices, including mobile phones and laptops. Evidence must be captured.<br>2. external access will revoke until HOD approval on first instance within 3 working days.<br>3. The incident will be closed following the completion of the subsequent instances.<br>4. Declaration letter/email to get the confirmation of non-performance of such activities in the future.<br>5. System access will revoke until HOD approval on first instance within 7 working days. |
| 2       | DLP      | Email                | Sharing Multiple file of customer / Company data outside PFL domain through email without required approval.                                           | Critical | Warning Email from HOD/ Refer to EDC based on HOD OR SPOC response               | To be referred to EDC (through HR) | 1. Ensure the deletion of data from external IDs as well as local devices, including mobile phones and laptops. Evidence must be captured.<br>2. external access will revoke until HOD approval on first instance within 3 working days.<br>3. The incident will be closed following the completion of the subsequent instances.<br>4. Declaration letter/email to get the confirmation of non-performance of such activities in the future.<br>5. System access will revoke until HOD approval on first instance within 7 working days. |
| 3       | DLP      | Email                | send "explicit content," "adult content," to employees or outside the PFL network.                                                                     | Critical | To be referred to EDC (through HR)                                               |                                    | 1. External email will block after analysis if applicable.<br>2. The incident will be closed following the completion of the subsequent instances.                                                                                                                                                                                                                                                                                                                                                                                       |
| 4       | DLP      | Web                  | Uploaded a single piece of the customer's Personally Identifiable Information (PII) data or company data to an external website without authorization. | High     | Warning Email from Function Head/ SPOCs/ HOD                                     | To be referred to EDC (through HR) | 1. Respective external website will be blocked after analysis.<br>2. The incident will be closed following the completion of the subsequent instances.<br>3. User needs to submit Declaration letter/email to confirm non-performance of such activities in the future.                                                                                                                                                                                                                                                                  |
| 5       | DLP      | Web                  | Uploaded multiple pieces of customers' Personally Identifiable Information (PII) or company data to an external website without authorization.         | Critical | Warning Email from HOD/ Refer to EDC based on HOD OR SPOC response               | To be referred to EDC (through HR) | 1. Respective external website will be blocked after analysis.<br>2. The incident will be closed following the completion of the subsequent instances.<br>3. Declaration letter/email to confirm non-performance of such activities in the future.<br>4. System access will revoke until HOD approval on first instance within 7 working days.                                                                                                                                                                                           |
| 6       | DLP      | External Device/ App | Transfer Company / Customer/employee's data through unauthorized Application/Devices                                                                   | Critical | Warning Email from HOD/ Refer to EDC based on HOD OR SPOC response               | To be referred to EDC (through HR) | 1. Respective external devices/ app access will be revoked after analysis.<br>2. The incident will be closed following the completion of the subsequent instances.<br>3. Declaration letter/email to get the confirmation of non-performance of such activities in the future.                                                                                                                                                                                                                                                           |
| 7       | DLP      | Printing             | Printing out the customer's Personally Identifiable Information (PII) data or the                                                                      | High     | Warning Email from Function Head/ SPOCs/ HOD                                     | To be referred to EDC (through HR) | 1. Printing access will block after analysis.<br>2. Justification and declaration letter/email to confirm non-performance of such activities in the future.                                                                                                                                                                                                                                                                                                                                                                              |